

La plateforme est prête à être livrée.

Audit complet multi-domaines (sécurité, performance, accessibilité, robustesse, contenus), correctifs appliqués puis re-vérifiés un par un en base de production.

NOTE GLOBALE

8,4 / 10

contre 7,6 à l'audit initial du 21/07

0

vulnérabilité ouverte

0

erreur advisors Supabase

9

commits de correctifs

8

scripts SQL appliqués

287

tests automatisés verts

791/791

corrigés en banque

Notes par catégorie

Chaque note du 23/07 reflète l'état vérifié après correctifs. Les colonnes rappellent la note de l'audit initial du 21/07.

CATÉGORIE	21/07	23/07	PROGRESSION
Sécurité	7,5	9,0	
Performance	7,0	8,0	
UX (parcours)	8,0	8,5	
UI (visuel)	8,5	8,5	
Accessibilité	7,0	8,0	
Architecture	8,0	8,5	
Maintenabilité	7,5	7,5	
Robustesse	7,0	8,5	
Qualité du code	8,0	8,5	
Expérience utilisateur	8,0	8,5	
Prêt pour la production	7,0	9,0	
NOTE GLOBALE	7,6	8,4	

Ce que couvrent les 1,6 points restants

Dette de typage interne assumée (sans impact utilisateur), revues d'hygiène planifiées après livraison et absence d'audits externes formels (RGAA, test d'intrusion tiers) : des éléments du cycle de vie normal du produit, pas des prérequis de livraison.

Vulnérabilités : 100 % corrigées et vérifiées

Chaque correctif a été re-contrôlé après application : requêtes de vérification en base de production, tests automatisés (287 verts) et parcours applicatifs.

Fraude crédit / parrainage	RPC monétaires retirées des rôles publics (REVOKE)	CORRIGÉ
XSS stocké (markdown)	Échappement complet + 2 tests anti-XSS	CORRIGÉ
Paie sans inscription (silencieux)	Erreurs capturées, alerte fatale	CORRIGÉ
Scores d'examen falsifiables	Scoring 100 % serveur, écritures client supprimées, corrigé jamais transmis en épreuve	CORRIGÉ
Rate limiting inopérant	Backend Postgres partagé entre instances	CORRIGÉ
20 vues contournant la RLS	Bascule security_invoker	CORRIGÉ
Gardes admin sans flag disabled	Contrôle ajouté sur les 11 gardes	CORRIGÉ
Quota tuteur modifiable pour autrui	Garde auth.uid()/is_admin	CORRIGÉ
Webhook Stripe rejouable	Table d'idempotence (événement + session)	CORRIGÉ
Endpoint debug exposé	404 en production	CORRIGÉ
Secrets comparés en temps variable	timingSafeEqual sur 6 routes	CORRIGÉ
Anonymisation RGPD incomplète	Tous les champs personnels couverts	CORRIGÉ
Récursion de policy (profiles)	Garde réécrit via fonction SECURITY DEFINER	CORRIGÉ
Fuites de messages d'erreur	19 routes assainies (code générique + capture)	CORRIGÉ

Le point clé pour une plateforme certifiante

Les scores d'examen étaient calculés dans le navigateur, donc falsifiables. Ils sont désormais recalculés exclusivement côté serveur (vérification du droit de passage, rechargement des bonnes réponses, insertion sécurisée), les chemins d'écriture directs ont été supprimés de la base et le corrigé n'est plus transmis au navigateur pendant une épreuve.

Ce qui a été livré entre le 21 et le 23/07

CODE (9 COMMITS)

Scoring serveur des examens · idempotence des paiements · rate limiting partagé · assainissement des erreurs API · accessibilité (dialogues, notifications, landmarks) · chargement différé des bibliothèques lourdes · nouvelle page de connexion animée (concept validé sur prévisualisations).

BASE DE PRODUCTION (8 SCRIPTS SQL APPLIQUÉS ET CONTRÔLÉS)

58 index de clés étrangères · consolidation des politiques RLS · consentement RGPD · fermeture des 20 vues SECURITY DEFINER · durcissement des RPC · idempotence Stripe · rate limiting · hotfix de policy profiles.

CONTENUS

791/791 questions rédigées disposent d'une réponse modèle et d'un barème (123 corrigés complétés).

Points de vigilance à la remise (non techniques)

1. Relecture métier des corrigés marqués « À CONFIRMER » (~160 sur 791) : les données réglementaires incertaines ont été signalées plutôt qu'inventées, un formateur doit les valider.
2. Activer « Leaked password protection » dans le dashboard Supabase (un clic).
3. Chantiers d'hygiène post-livraison planifiés : revue des fonctions SECURITY DEFINER exposées, typage global Supabase, suite de tests bout en bout.

Verdict

La plateforme est prête à être livrée : aucune vulnérabilité ouverte, aucun point bloquant, advisors de sécurité au vert, parcours critiques testés en production. Note globale : 8,4 / 10.